Heritage Bites — technical launch checklist

Updated 27 October 2026, after the owner's content and rules were confirmed

Where the site stands

The public storefront and the customer journey are complete and tested: menu, plate builder, basket, collection or delivery, checkout by card or cash on collection, secure order receipt, loyalty-card lookup, a contact form that reaches the business inbox, and the five approved customer policies.

The catalogue is the owner-signed content: **Traditional plates R100** (five proteins, four starches, four sides) and **Contemporary plates R130** (three proteins, five starches, six sides), delivery included, **Thursdays and Fridays 12:00–13:30**, delivery in **Rosebank and Sandton**, **R100 minimum order**.

What is not yet live is operational, not cosmetic. In order:

Before taking live orders

1. **Order email alert.** Set the Gmail App Password and related values from `.env.example` in the host's secret settings. Until then orders are saved and their alerts queue as `waiting_config`.
2. **Live card payments.** Set `YOCO_SECRET_KEY` and `YOCO_PUBLIC_KEY` from the live Yoco merchant account. Step-by-step in [`production-payments-yoco.md`](production-payments-yoco.md). Until then checkout is in sandbox test-card mode.
3. **Contact inbox.** The Formspree endpoint is wired and each submission is saved locally as well. Confirm which address it delivers to and who replies.
4. **Staff order workflow.** There is no staff console. The email alert is a summary, not a queue: nobody can accept, update, complete or cancel a ticket from the site. Someone must watch the inbox during the service window and confirm timing with the customer. Either accept that manual process formally, or commission a small protected order queue.
5. **Collection point.** The exact Standard Bank Rosebank/Sandton point is still to be confirmed. The site currently says so honestly instead of publishing a guessed address.

Launch hardening

1. **Production data and backups.** Orders, messages, loyalty stamps and the email outbox are JSON files in `HB_DATA_DIR`. Point that at a persistent volume, back it up weekly, and note the store is single-instance only. Move to a transactional database before running more than one server or at meaningful volume.
2. **Hosting.** A Node.js 20+ host with HTTPS and persistent disk (Afrihost Cloud/VPS, Render, Railway and similar all work; shared hosting does not). Set every secret through the host's secret settings — never in the repository, a PDF or a chat message.
3. **Monitoring.** Uptime check on `/api/health`, error logging, and an alert if the order email worker starts failing. Without this, a silent SMTP failure means silent lost orders.

4. **Rate limiting and abuse controls** on `/api/contact`, `/api/orders` and `/api/passport`. Not implemented yet.
5. **Security review** of the deployed configuration: HTTPS/HSTS, no debug data in responses, dependency audit, and confirmation that the tracking token is the only way to read an order.

Content still outstanding from the business

1. Photos for **Tlhakwana** and **Smiley** (both currently show a "photo coming soon" panel rather than the wrong dish).
2. Drinks and any add-ons, with prices, if they are to be sold online.
3. Direct **Uber Eats** and **Mr D** store URLs, if used. The buttons stay disabled until real store links exist; no search-result links.
4. A lawyer's or accountant's review of the five published policies.

Implemented, no longer outstanding

- Menu, prices, portions, hours and contact details — applied as signed off.
- Delivery boundary — enforced in the API, with a clear customer message outside Rosebank/Sandton.
- Opening hours — the service window is real: inside it orders are for today, outside it they are pre-orders labelled with the next window on the receipt and in the order email.
- Minimum order and delivery fee — enforced; delivery is included in the plate price, so no fee line appears.
- Contact form — forwards to the business Formspree inbox and keeps a local fallback record.
- Policies — privacy, terms, delivery/collection, refunds and cancellations published at `/policies`.
- Live card payments — PCI-safe hosted-checkout path built and gated on Yoco keys; raw card data is refused once live.
- Cash — on collection only, as confirmed.
- Retired content — unapproved dishes, add-ons, discount codes, testimonials and day-of-week promotions removed.